

CISSP Printable Practice Exam 05 - Domain 5 - Identity and Access Management (IAM)

Domain 5

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP1-079)

Scenario: A regional utility permits administrators to manage critical servers from corporate workstations. A stolen administrator password recently allowed an attacker to begin an interactive sign-in, although monitoring stopped the session before changes were made.

Which change would MOST directly reduce the likelihood that another stolen password could be used to establish an administrative session?

- A. Require a second authentication factor that is resistant to credential replay
- B. Shorten the inactivity timeout for all established administrative sessions
- C. Record every privileged command in a centralized activity log
- D. Reconfirm each administrator's assigned privileges every quarter

Question 2 (CISSP1-080)

Scenario: A manufacturing plant uses one shared maintenance account because several technicians must respond quickly to equipment failures. The account has broad permissions, and investigators cannot determine which technician made a recent configuration change.

What is the BEST way to preserve rapid response while establishing accountability?

- A. Keep the shared account and require technicians to record their names in a paper log
- B. Issue individually attributable accounts and grant the required maintenance role to each technician
- C. Change the shared account password after every maintenance event
- D. Allow the supervisor to disclose the shared password only when an outage occurs

Question 3 (CISSP1-081)

Scenario: An online services organization resets a user's password after confirming account compromise. The application uses long-lived session tokens that remain valid after a password change.

Which action should the organization take FIRST to contain continued use of the compromised account?

- A. Reduce the minimum password age for the affected account
- B. Invalidate the user's existing sessions and authentication tokens
- C. Add the user's address to a security notification list
- D. Review the user's business role at the next certification cycle

Question 4 (CISSP1-082)

Which TWO combinations provide two different authentication factor categories? Select 2 of the 5 options below.

- A. A password and a memorized personal identification number
- B. A hardware security key and a fingerprint
- C. A passphrase and the answer to a knowledge-based question
- D. A smart card and a personal identification number
- E. A fingerprint and facial recognition

Question 5 (CISSP1-083)

Scenario: A nonprofit is replacing an application that stores user passwords with a general-purpose fast hash. The security architect wants a design that limits the value of a stolen credential database and makes large-scale offline guessing more expensive.

Which approach BEST meets the architect's objective?

- A. Encrypt all passwords with one reversible key stored on the application server
- B. Store each password with a unique salt using an adaptive password-hashing function
- C. Apply the same random salt to every password before using the existing fast hash
- D. Encode each password and restrict read access to the credential table

Question 6 (CISSP1-084)

Scenario: A university wants employees to use their institutional credentials to access a browser-based human resources service operated by an external provider. The university must remain responsible for authenticating its employees, and the provider must consume an assertion to create the service session.

Which architecture BEST satisfies this requirement?

- A. The university acts as a SAML identity provider and the external service acts as a service provider
- B. The external service acts as an OAuth resource server and issues university passwords
- C. The university acts as a SAML service provider and delegates authentication to the external service
- D. The external service uses an authorization code as proof of the employee's identity without an identity assertion

Question 7 (CISSP1-085)

Scenario: A development team uses OAuth so a scheduling application can read a user's calendar through an API. The team now proposes treating the OAuth access token by itself as proof that a particular user authenticated to the scheduling application.

What is the MOST important flaw in the proposal?

- A. OAuth access tokens can be used only with applications inside one security domain
- B. OAuth delegates access to a resource but does not, by itself, define an authentication assertion for the client
- C. OAuth requires the resource owner to disclose credentials directly to every client application
- D. OAuth prevents a resource server from limiting the scope of delegated access

Question 8 (CISSP1-086)

Scenario: A media organization is implementing sign-in for several modern web and mobile applications. Its authorization server already supports OAuth, and the applications require standardized claims about the authenticated user.

Which addition MOST directly provides the required authentication information?

- A. OpenID Connect with a validated ID token intended for the client
- B. A broader OAuth access-token scope for each protected API
- C. A refresh token stored as the user's permanent identity record
- D. A resource-server response containing the client's secret

Question 9 (CISSP1-087)

Scenario: A logistics company will trust a partner's identity service so partner personnel can access a shared shipment portal. The parties want to reduce unauthorized access caused

by stale partner accounts and improperly accepted assertions.

Which TWO controls are MOST important before enabling the federation? Select 2 of the 5 options below.

- A. Define assurance, lifecycle, incident, and account-termination responsibilities in the trust agreement
- B. Validate assertion signatures, issuer, audience, and validity period at the relying service
- C. Permit all partner identities to receive one common local administrator role
- D. Retain partner accounts indefinitely so past shipment records remain attributable
- E. Allow the partner to select any claim names without an agreed mapping

Question 10 (CISSP1-088)

Scenario: A global retailer plans to use one cloud identity service for single sign-on to most workforce applications. Executives are concerned that an identity-service outage or compromise could affect many business functions at once.

Which design response BEST addresses the concentration of risk without abandoning SSO?

- A. Give each employee a shared emergency account accepted by all applications
- B. Implement resilient identity-service architecture and tightly controlled break-glass access for critical systems
- C. Allow every application to retain a permanent copy of the employee's primary password
- D. Disable centralized logging so a compromise cannot alter all authentication records

Question 11 (CISSP1-089)

Scenario: A research consortium shares documents among employees, visiting scientists, and contractors. Access depends on project membership, document sensitivity, contract status, geographic location, and whether the request occurs during an approved collaboration period. The combinations change frequently.

Which access control model BEST supports these requirements with the least role proliferation?

- A. Attribute-based access control
- B. Discretionary access control
- C. Mandatory access control based only on fixed security labels
- D. Role-based access control using a separate role for every possible combination

Question 12 (CISSP1-090)

Scenario: An insurance company is centralizing authorization. One component will evaluate policy using identity and resource attributes, while a gateway in front of each application will intercept requests and carry out the resulting allow-or-deny decision.

How should the two components be classified?

- A. The evaluator is the policy enforcement point, and the gateway is the policy decision point
- B. The evaluator is the policy decision point, and the gateway is the policy enforcement point
- C. Both components are policy decision points because both participate in authorization
- D. Both components are policy enforcement points because neither authenticates the user

Question 13 (CISSP1-091)

Scenario: A government agency requires documents and users to carry formal security labels. Individual document owners must not be able to grant access at their discretion, and a centrally defined policy must govern interactions between clearances and classifications.

Which authorization model is MOST appropriate?

- A. Discretionary access control
- B. Role-based access control
- C. Mandatory access control
- D. Risk-based access control

Question 14 (CISSP1-092)

Scenario: A financial services firm assigns application permissions through job roles. It also needs a centrally managed condition that blocks all remote access to a sensitive function outside approved hours, regardless of the user's role.

Which mechanism BEST expresses the additional condition?

- A. A discretionary access list maintained separately by each data owner
- B. A rule-based access control rule evaluated for every request
- C. A new permanent role for every employee who works during approved hours
- D. A mandatory classification label assigned to the time of day

Question 15 (CISSP1-093)

Scenario: A payment processor wants ordinarily permitted account access to receive additional scrutiny when sign-in behavior is anomalous, the device is unmanaged, or the transaction is unusually sensitive. Existing job entitlements must remain the baseline.

What is the BEST authorization strategy?

- A. Replace all job entitlements with resource-owner discretion
- B. Apply risk-based decisions that can require step-up authentication or deny high-risk requests
- C. Grant permanent elevated roles to users who frequently trigger risk checks
- D. Approve access solely from the sensitivity label without considering request context

Question 16 (CISSP1-094)

Scenario: A sales employee with access to customer records is being terminated at the end of a meeting. Human resources, the manager, and the identity team know the scheduled time. Several cloud applications receive accounts from the central identity platform.

Which action is MOST important for the identity team to coordinate?

- A. Disable access at the effective termination time and propagate revocation to connected services
- B. Wait for the next monthly entitlement review before changing the account
- C. Remove the employee from the office directory but retain all application sessions
- D. Transfer the employee's password to the manager for business continuity

Question 17 (CISSP1-095)

Scenario: An employee moves from procurement to accounts payable. The organization commonly adds the new department's permissions immediately but leaves removal of old permissions for a later cleanup project.

Which lifecycle control BEST prevents privilege accumulation in this situation?

- A. Copy the access of a highly experienced accounts-payable employee
- B. Treat the transfer as a controlled remove-and-add event based on approved role requirements
- C. Retain procurement access in case the employee assists the former team
- D. Allow the employee to choose which legacy permissions remain useful

Question 18 (CISSP1-096)

Scenario: A hospital wants database administrators to use standard accounts for daily work and receive elevated production privileges only for approved maintenance. The privileges should not remain after the work window.

Which TWO controls BEST implement this just-in-time objective? Select 2 of the 5 options below.

- A. Require an approved request tied to the administrator's individual identity
- B. Automatically expire the elevated entitlement at the end of the authorized period
- C. Publish one standing privileged password to the entire database team
- D. Convert every administrator's standard account into a permanent privileged account
- E. Allow administrators to renew elevation indefinitely without additional approval

Question 19 (CISSP1-097)

Scenario: A pharmaceutical company finds that managers approve quarterly access lists without understanding cryptic group names. The identity team wants future reviews to produce meaningful decisions about continued business need.

Which improvement would MOST increase the effectiveness of the reviews?

- A. Provide reviewers with entitlement descriptions, user context, ownership, and risk information
- B. Ask the identity operations team to approve every entitlement on behalf of managers
- C. Automatically retain access whenever a reviewer does not respond by the deadline
- D. Show only the date each technical group was created to simplify the review

Question 20 (CISSP1-098)

Scenario: A transportation company discovers hundreds of service accounts with no recorded owner, no expiration or review date, and privileges accumulated across retired applications. Some credentials are embedded in automation scripts.

What should the identity governance team do FIRST?

- A. Delete every service account immediately, including those used by active systems
- B. Inventory usage and dependencies, assign accountable owners, and validate each account's required privileges
- C. Give all service accounts the same enterprise role to simplify administration
- D. Exclude nonhuman identities from lifecycle controls because no employee signs in with them

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP1-079) - Correct: A

A replay-resistant second factor most directly prevents possession of a stolen password from being sufficient to establish a session. A shorter timeout limits exposure after a session exists, and command logging improves accountability after access. Quarterly privilege reviews address authorization and entitlement appropriateness, not the immediate authentication weakness.

Question 2 (CISSP1-080) - Correct: B

Individual accounts tied to a maintenance role preserve operational access while making activity attributable to a specific technician. A paper log can be incomplete or falsified, and rotating a shared password does not identify the person using it. Supervisor-controlled disclosure limits availability but still leaves activity associated with the same shared identity.

Question 3 (CISSP1-081) - Correct: B

Invalidating active sessions and tokens immediately removes the attacker's continuing authenticated state. Changing password policy does not terminate tokens already issued. Notifications may support response communications, and a later role review may identify excessive privileges, but neither contains the active session first.

Question 4 (CISSP1-082) - Correct: B, D

A hardware key plus a fingerprint combines possession and inherence, while a smart card plus a personal identification number combines possession and knowledge. A password with a personal identification number and a passphrase with a knowledge-based answer each use two knowledge credentials. A fingerprint and facial recognition are both inherence factors, so using both does not create factor-category diversity.

Question 5 (CISSP1-083) - Correct: B

A unique salt defeats precomputed comparisons across accounts, and an adaptive password-hashing function raises the cost of each offline guess. Reversible encryption creates dependence on protecting a decryption key. One common salt still permits efficient comparison across accounts, while encoding provides no cryptographic protection even if database permissions are useful defense in depth.

Question 6 (CISSP1-084) - Correct: A

In this federation pattern, the university authenticates the employee as the identity provider and sends a signed SAML assertion to the service provider. Reversing those roles would transfer authentication responsibility to the external service. OAuth resource access and an authorization code alone do not provide the requested SAML identity assertion and should not require the provider to issue university passwords.

Question 7 (CISSP1-085) - Correct: B

OAuth is an authorization framework for delegated resource access; possession of an access token alone is not a standardized assertion that the client authenticated a particular end user. OpenID Connect adds an identity layer for that purpose. OAuth can operate across trust domains, avoids routine credential disclosure to clients in appropriate flows, and supports scoped access.

Question 8 (CISSP1-086) - Correct: A

OpenID Connect adds authentication to OAuth-based flows and provides an ID token containing claims for the client, subject to validation of issuer, audience, signature, and related

properties. Expanding API scopes changes authorization, not authentication. Refresh tokens obtain new tokens and are not identity records, while a client secret must not be exposed by a resource server.

Question 9 (CISSP1-087) - Correct: A, B

A federation requires both governance of the identity lifecycle and rigorous validation of the assertions crossing the trust boundary. The trust agreement establishes who must provision, disable, notify, and respond, while signature, issuer, audience, and time validation prevents acceptance of forged or misdirected assertions. Broad administrative access, indefinite active accounts, and undefined claim mappings undermine least privilege and reliable authorization.

Question 10 (CISSP1-088) - Correct: B

Resilient identity services reduce availability risk, and narrowly scoped, monitored break-glass access supports continuity when federation is unavailable. Shared emergency accounts weaken accountability. Distributing reusable passwords expands credential exposure, and disabling centralized logging removes detection evidence rather than containing identity-provider risk.

Question 11 (CISSP1-089) - Correct: A

ABAC evaluates policies using subject, resource, action, and environmental attributes, making it well suited to dynamic combinations such as project, contract, location, and time. DAC places decisions with resource owners and may be inconsistent. Label-based MAC does not naturally express all listed conditions, while encoding every combination as an RBAC role creates role explosion.

Question 12 (CISSP1-090) - Correct: B

The policy decision point evaluates applicable policy and returns an authorization decision. The policy enforcement point intercepts the access request and enforces that decision at the resource boundary. Participation in one authorization flow does not make both components the same, and authentication is separate from these authorization roles.

Question 13 (CISSP1-091) - Correct: C

Mandatory access control uses centrally administered labels and rules, preventing resource owners from independently changing access to classified information. DAC explicitly gives owners discretion. RBAC organizes permissions around job functions but does not inherently enforce clearance and classification labels, while risk-based access changes decisions according to assessed contextual risk.

Question 14 (CISSP1-092) - Correct: B

A centrally applied rule can evaluate time and connection context for every request independently of the user's role. Owner-maintained discretionary lists would fragment enforcement. Creating permanent roles for a changing time condition misuses RBAC and increases administration, while a classification label is not the appropriate representation of time-based access.

Question 15 (CISSP1-093) - Correct: B

Risk-based access can combine baseline entitlement with signals such as device posture, behavior, location, and transaction sensitivity, then allow, challenge, or deny the request. Owner discretion does not provide consistent adaptive decisions. Permanent elevation rewards risky patterns and violates least privilege, while relying only on a label ignores the requested contextual analysis.

Question 16 (CISSP1-094) - Correct: A

Revocation aligned with the effective termination time closes the access window while respecting the coordinated personnel process, and propagation addresses downstream services and sessions. A monthly review is too late. Directory removal alone may not revoke application access, and transferring a personal password breaks accountability and proper credential handling.

Question 17 (CISSP1-095) - Correct: B

A role transfer should trigger removal of access no longer required and addition of access approved for the new role, avoiding entitlement accumulation. Copying another employee can reproduce excessive or exceptional privileges. Keeping old access by default and letting the user choose both bypass business ownership, least privilege, and separation-of-duties review.

Question 18 (CISSP1-096) - Correct: A, B

An individually attributable approval and automatic expiration provide the essential governance and time boundary for just-in-time privilege. A shared password weakens accountability. Permanent elevation defeats the objective, and unlimited self-renewal can turn temporary access into standing privilege without renewed business authorization.

Question 19 (CISSP1-097) - Correct: A

Reviewers need intelligible entitlement descriptions, relevant user and role context, accountable ownership, and risk information to decide whether access remains justified. Identity operations usually cannot attest to each user's business need. Default retention for nonresponse preserves potentially inappropriate access, and group-creation dates do not explain permissions or current necessity.

Question 20 (CISSP1-098) - Correct: B

The team must first understand dependencies and establish ownership before safely remediating nonhuman identities; it can then remove unused accounts, reduce privileges, rotate exposed credentials, and define review and retirement controls. Immediate deletion could disrupt critical services. A common broad role increases exposure, and service accounts require lifecycle governance precisely because unmanaged nonhuman access can persist unnoticed.